Connexion externe et maintenance partagée

Montval · ZF-02 / REG-02 — Complément au compte-rendu J5

Constat : une session VPN utilise le compte partagé **maint-shared** depuis une adresse externe. Pendant cette fenêtre, MAINT-01 écrit une consigne de **12 °C** sur REG-02. Le rapprochement justifie une investigation, mais **n'identifie pas la personne ayant envoyé la commande**.

Les traces disponibles

Trace	Fait établi dans les sources du scénario
VPN	Source **203.30.113.77**, compte **maint-shared**, cible **MAINT-01**. Session corrigée : **09:12–09:19** le 8 octobre 2026. Heures brutes : 09:14:10–09:21:10 ; horloge VPN en avance de 2 min 10 s.
Commande Modbus	À **09:14**, trames 9/10 : **10.30.20.15:41002 → 10.30.10.22:502**. FC06, registre PDU 0, valeur **120 = 12 °C**. Réponse normale du régulateur à +30 ms.
Exploitation	SUP et mesures corroborent le changement et la hausse de température. Alarme à **09:52**. Retour à 4 °C autorisé à 10:18, documenté à **10:21**.
Autorisation	FM-426 connu couvre **08:30–09:00**. Aucun ticket n'est fourni pour la session de 09:12 ; FrigoMaint ne déclare pas de changement à 12 °C. Cela ne prouve pas l'absence exhaustive de toute autorisation.

Qui a utilisé l'accès ?

Le **compte** est connu, l'**auteur humain reste inconnu**. Le technicien A est déclaré pour la session précédente ; le compte partagé ne permet pas de lui attribuer la suivante. Erreur, automatisation, usage abusif d'un accès légitime ou compromission restent à départager.

L'IP externe désigne la source enregistrée par le VPN, éventuellement une sortie partagée ou un relais. Le PCAP montre ensuite **MAINT-01 → REG-02** : il ne démontre ni accès direct du régulateur depuis Internet, ni lien causal certain avec la session VPN. Aucun pays, opérateur ou propriétaire n'est attribué à cette IP.

Pièces : acces_distants_VPN.csv (lignes 4–5), modbus_REG02_capture.pcap (trames 9/10), evenements_SUP01.csv, températures ZF-02, maintenance_FrigoMaint.csv et inventaire des horloges. PCAP synthétique partiel : 18 trames ; quantités FC03 incohérentes, signalées dans le rapport complet.

Agir maintenant, puis corriger durablement

Statut : propositions pour Montval, à coordonner avec exploitation, maintenance, IT et FrigoMaint. Aucune suspension de VPN ni intervention sur une installation réelle n'est attestée ici.

À l'instant T — préserver le froid, les preuves et les accès utiles

1. Vérifier le processus. Lire consigne, température, alarmes et état du groupe ; prévoir une mesure indépendante et une surveillance sur place. L'exploitation décide des lots et de la poursuite d'activité.

2. Conserver les traces en parallèle. Exporter VPN, authentification, SUP, pare-feu, tickets et configurations ; conserver originaux, empreintes, fuseaux et écarts d'horloge. Préserver les traces volatiles utiles de MAINT-01 si compatible avec l'urgence. Éviter nettoyage et redémarrage par défaut.

3. Contenir l'accès suspect. Vérifier les sessions actives, fermer celles concernées et suspendre le compte partagé sur décision coordonnée. La session documentée finit à 09:19 : elle ne peut pas être coupée rétroactivement. Désactiver un compte ne ferme pas toujours une session déjà ouverte ; bloquer une seule IP ne suffit pas.

4. Maîtriser la maintenance. Restreindre MAINT-01 si nécessaire sans couper indistinctement la supervision. Prévoir un accès alternatif autorisé ; renouveler les secrets concernés depuis un environnement de confiance, sans les exposer au poste suspect.

5. Restaurer et vérifier. Corriger la consigne avec autorisation, tracer avant/après et suivre le refroidissement. Le retour à 4 °C est déjà documenté à 10:21. Vérifier aussi lectures, supervision et accès utiles ; la baisse de température ne clôt pas seule l'incident.

Ensuite — lever les incertitudes et réduire la récidive

Relier session et commande : demander identifiants de session VPN, IP du tunnel, traces d'accès au poste, processus/outils et connexions sortantes. Recouper avec les intervenants, IP de sortie et tickets FrigoMaint ; vérifier l'intégrité de MAINT-01.

Individualiser et limiter : comptes nominatifs, MFA, accès temporaires liés à un ticket, VPN puis bastion en DMZ industrielle ; consultation séparée des modifications et procédure d'urgence tracée. Tester expiration et révocation.

Surveiller et pérenniser : centraliser journaux et horodatage, alerter sur écritures ou connexions hors fenêtre, qualifier le contrôle Modbus et préparer le remplacement de REG-02. Ces mesures ne corrigent pas ses défauts internes.

Limite des essais : C01 journalise les refus IT directs du PoC ; elle ne démontre pas la détection d'une écriture depuis une origine autorisée. La conformité des produits et la remise en service relèvent de l'exploitation avec les spécialistes concernés.